KEMENTERIAN PENDIDIKAN, TINGGI, SAINS, DAN TEKNOLOGI

POLITEKNIK NEGERI BENGKALIS

Jalan Bathin Alam, Sungai Alam, Bengkalis, Riau 28711

Telepon: (+62766) 24566 | Fax: (+62766) 800 1000 | www.polbeng.ac.id

LEMBAR KERJA PRAKTIKUM INDIVIDU

PENETRATION TESTING

Pertemuan 6: Scanning, Enumeration, dan Threat Modeling

Program Studi Sarjana Terapan Keamanan Sistem Informasi - Politeknik Negeri Bengkalis

Nama	M. Arifin Ilham
NIM	6404240008
Kelas	KSI 5A
Tanggal Praktik	09/10/2026
Target Web	https://nyamankost.ours.web.id

A. Tujuan Praktikum

- Melakukan scanning dan enumeration secara terkendali pada target web riil yang berizin.
- Mencatat evidence yang dapat ditelusuri.
- Menyusun threat model dan prioritas pengujian berdasarkan hasil recon.

B. Verifikasi Scope

Sumber: RoE Pentest KSI 5A 2026.pdf - ditandatangani 25/09/2026

Item Scope	Jawaban / Bukti
Bukti Izin	RoE Pentest KSI 5A 2026.pdf - Revis Irwan Gea (Tim Pengembang), Nurmi Hidayasari (Dosen), M. Arifin Ilham (Pelaksana). Tanggal: 25/09/2026.
Domain/URL in-scope	https://nyamankost.ours.web.id - hanya lapisan aplikasi web (HTTP/HTTPS). RoE Bagian 4.
IP in-scope	Tidak ditetapkan eksplisit. DNS: 104.21.92.41 & 172.67.186.51 (Cloudflare anycast). Port scanning ke IP/domain DILARANG per RoE Bagian 5.
Out-of-scope	Lapisan jaringan/infrastruktur/server; eksploitasi OS/server; aksi destruktif; social engineering; port scanning/Nmap terhadap domain/IP target.
Waktu Pengujian	Minggu 3 s.d. Minggu 12 mengikuti jadwal praktikum. Tidak ada jendela waktu wajib dihindari (belum ada mitra yang bergantung pada uptime).
Rate/Concurrency Limit	Tidak ditetapkan eksplisit dalam RoE. Mengikuti batas wajar agar tidak mengganggu pengguna lain di server shared hosting.
Metode yang Dilarang	Port scanning/Nmap; eksploitasi tingkat OS/server; menghapus/mengubah data permanen; social engineering; publikasi data/kredensial di luar keperluan akademik.
Kontak Penghentian	Nurmi Hidayasari (Dosen): 0811-7500-891 | Revis Irwan Gea (Tim Pengembang): 0812-6534-2848

C. Log Aktivitas

No	Timestamp	Target	Aktivitas	Command/Tool	Hasil Singkat
1	09:37:03	https://nyamankost.ours.web.id	HTTP Baseline (HTTPS)	curl -I https://nyamankost.ours.web.id	HTTP/2 200, server: cloudflare, PHP/8.5.11, XSRF-TOKEN cookie
2	09:39:03	http://nyamankost.ours.web.id	Cek Redirect HTTP ke HTTPS	curl -I http://nyamankost.ours.web.id	301 Moved Permanently ke https://nyamankost.ours.web.id/
3	~09:40	https://nyamankost.ours.web.id	Fingerprinting teknologi	whatweb https://nyamankost.ours.web.id	Cloudflare, PHP 8.5.11, HTML5, IP 104.21.92.41, cookies
4	~09:45	.../robots.txt	Enumerasi robots.txt	curl https://nyamankost.ours.web.id/robots.txt	User-agent: * / Disallow: (kosong - tidak ada path diblokir)
5	~09:46	.../sitemap.xml	Enumerasi sitemap.xml	curl https://nyamankost.ours.web.id/sitemap.xml	404 Not Found - HTML Tailwind CSS (indikasi Laravel)
6	09:48:28	.../wp-admin	Cek endpoint WordPress	curl -I https://nyamankost.ours.web.id/wp-admin	HTTP/2 404 - bukan WordPress
7	16:50	nyamankost.ours.web.id	Port scanning (di luar scope RoE)*	nmap -sV -sC -p 80,443,22 nyamankost.ours.web.id	Port 22 filtered, 80 & 443 open via Cloudflare proxy
8	~17:00	Target keseluruhan	Kompilasi dokumentasi evidence	-	8 evidence terdokumentasi (E-01 s.d. E-07)

Catatan Kepatuhan: Aktivitas No.7 (Nmap) berada di luar Exclusion List RoE Bagian 5. Hosting shared melarang port scanning. Evidence E-07 tetap didokumentasikan sebagai catatan faktual.

D. HTTP/HTTPS Baseline

Command: `curl -I https://nyamankost.ours.web.id | curl -I http://nyamankost.ours.web.id`

Parameter	Hasil
URL	https://nyamankost.ours.web.id
HTTP Status	HTTP/2 200 OK (HTTPS) | HTTP/1.1 301 Moved Permanently (HTTP)
Redirect	HTTP port 80 ke HTTPS port 443: 301 Moved Permanently ke https://nyamankost.ours.web.id/
Server Header	cloudflare (reverse proxy) | X-Turbo-Charged-By: LiteSpeed (web server backend)
Content-Type	text/html; charset=utf-8
Cookie / Security Attributes	XSRF-TOKEN: path=/; secure; samesite=lax [TANPA HttpOnly - RISIKO XSS+CSRF] nyamankost-session: path=/; httponly; secure; samesite=lax [Konfigurasi OK]
Teknologi Teridentifikasi	PHP/8.5.11, HTML5, Cloudflare CDN, LiteSpeed Web Server

Interpretasi:

[OK] HTTPS aktif dan redirect HTTP ke HTTPS sudah dikonfigurasi dengan benar.

[PERHATIAN] Header X-Powered-By: PHP/8.5.11 mengekspos versi PHP secara spesifik - memudahkan attacker mencari CVE.

[PERHATIAN] Cookie XSRF-TOKEN tidak memiliki flag HttpOnly - dapat dibaca JavaScript, risiko XSS + CSRF chain.

[OK] Cookie nyamankost-session sudah memiliki httponly dan secure.

[PERHATIAN] Tidak ditemukan header keamanan: Content-Security-Policy, X-Frame-Options, X-Content-Type-Options.

[INFO] Header server: cloudflare + cf-ray mengkonfirmasi seluruh traffic melewati Cloudflare edge network.

E. Fingerprinting Teknologi

Command: `whatweb https://nyamankost.ours.web.id`

Komponen	Hasil	Evidence	Tingkat Keyakinan
Web Server	LiteSpeed (backend) / Cloudflare (reverse proxy/CDN)	E-01: X-Turbo-Charged-By: LiteSpeed; E-03: server: cloudflare	Tinggi
Framework	Kemungkinan Laravel (indikasi: XSRF-TOKEN, pola session, Tailwind CSS di error page)	E-01, E-03, E-05.1	Sedang
CMS	Tidak ada CMS - bukan WordPress, Joomla, atau CMS umum lainnya	E-06: /wp-admin ke HTTP 404	Tinggi
Language/Runtime	PHP 8.5.11	E-01 & E-03: Header X-Powered-By: PHP/8.5.11	Tinggi
Reverse Proxy/CDN	Cloudflare - IP 104.21.92.41 & 172.67.186.51 (anycast)	E-01: server: cloudflare, cf-ray, nel; E-07: IP Cloudflare	Tinggi
JavaScript Library	Script type=module (modern JS module bundler)	E-03: WhatWeb Script[module]	Sedang

F. Port dan Service Scanning

Catatan Kepatuhan: Aktivitas port scanning menggunakan Nmap (E-07) secara eksplisit DILARANG dalam RoE Bagian 5 (Exclusion List) karena hosting menggunakan layanan shared (Rumah Web). Evidence E-07 tetap didokumentasikan sebagai catatan faktual, namun mahasiswa mengakui aktivitas ini berada di luar scope yang telah disepakati dan tidak akan diulang.

Command persis: `nmap -sV -sC -p 80,443,22 nyamankost.ours.web.id`

Port	Proto	Status	Service	Version / Info	Evidence
22	tcp	filtered	ssh	Tidak terdeteksi - diblokir Cloudflare/firewall hosting	E-07
80	tcp	open	http	Cloudflare http proxy | redirect ke HTTPS	E-07
443	tcp	open	ssl/http	Cloudflare http proxy + SSL | cert wildcard *.ours.web.id | valid s.d. 27 Des 2026	E-07

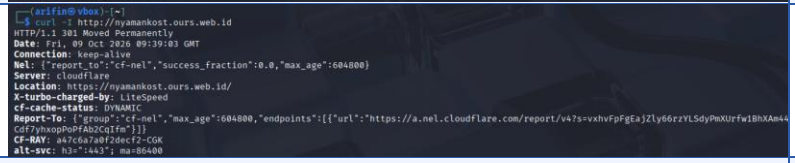
G. Interpretasi Status Port

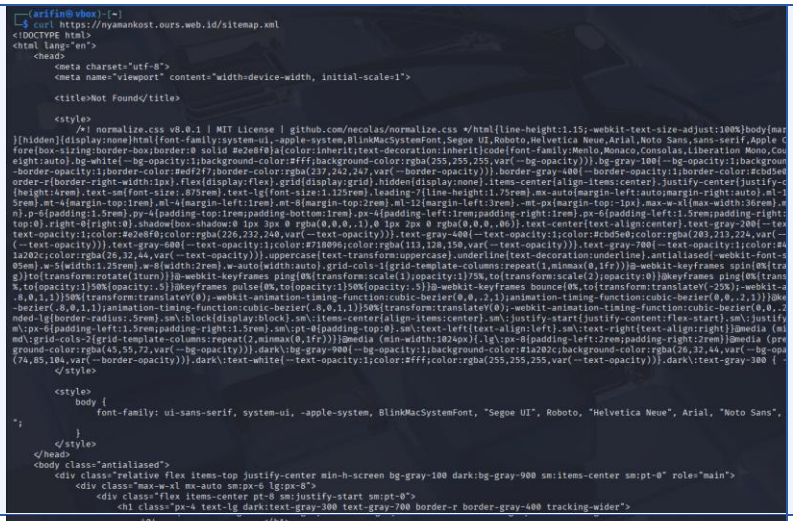
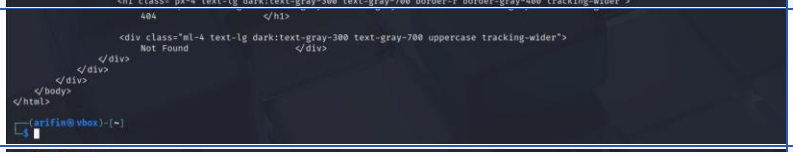
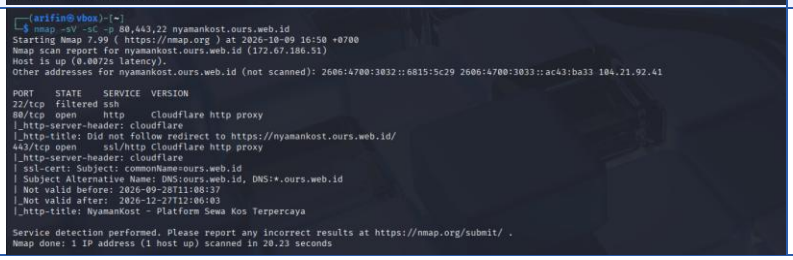
Status Port	Port yang Ditemukan	Interpretasi Mahasiswa
open	Port 80 & 443	Port 80 dan 443 aktif, diproksikan oleh Cloudflare. Port 80 redirect 301 ke port 443 (HTTPS). Port 443 melayani HTTPS dengan SSL wildcard aktif. Server backend (LiteSpeed) tidak dapat diakses langsung karena semua traffic difilter Cloudflare.
filtered	Port 22 (SSH)	Port 22 tidak merespons - diblokir oleh Cloudflare atau firewall hosting. Status filtered TIDAK SAMA dengan closed: SSH mungkin aktif di backend namun tidak dapat diakses dari internet. IP yang discan (172.67.186.51) adalah IP Cloudflare anycast, bukan IP server origin.
closed	(tidak ditemukan)	Tidak ada port berstatus closed dalam scan ini. Cloudflare memfilter semua akses sehingga status closed tidak dapat dikonfirmasi dari luar jaringan.

H. Enumerasi Endpoint/Service

No	Endpoint/Service	Metode	Informasi Ditemukan	Evidence	Interpretasi
1	/ (root)	curl -I + WhatWeb	HTTP/2 200; PHP/8.5.11; Cloudflare; XSRF-TOKEN (no HttpOnly); LiteSpeed; Title: NyamanKost - Platform Sewa Kos Terpercaya	E-01, E-03	Halaman utama aktif, stack teknologi teridentifikasi lengkap
2	http://... (HTTP)	curl -I	301 redirect ke HTTPS, Server: cloudflare, keep-alive	E-02	Redirect HTTP ke HTTPS dikonfigurasi dengan benar
3	/robots.txt	curl GET	User-agent: * Disallow: (kosong - tidak ada path yang diblokir)	E-04	robots.txt ada tapi kosong; tidak ada petunjuk direktori tersembunyi
4	/sitemap.xml	curl GET	404 Not Found - HTML error page penuh dengan Tailwind CSS class, judul Not Found	E-05.1, E-05.2	Tidak ada sitemap. Halaman 404 mengkonfirmasi framework custom PHP/MVC (indikasi Laravel)
5	/wp-admin	curl -I	HTTP/2 404, X-Powered-By: PHP/8.5.11, server: cloudflare	E-06	Bukan WordPress. Endpoint tidak ada, platform menggunakan custom framework
6	Port 80 (HTTP)	Nmap	Cloudflare http proxy, redirect ke HTTPS, server-header: cloudflare	E-07	Traffic HTTP diproksikan Cloudflare, redirect ke HTTPS
7	Port 443 (HTTPS)	Nmap	Cloudflare ssl proxy; SSL cert wildcard *.ours.web.id; valid 28 Sep s.d. 27 Des 2026	E-07	SSL aktif dan valid. Cloudflare menangani terminasi SSL. Title: NyamanKost
8	Port 22 (SSH)	Nmap	filtered - tidak merespons dari internet; commonName=ours.web.id	E-07	SSH kemungkinan ada di backend tapi diblokir Cloudflare/hosting firewall

I. Evidence Register

ID	Jenis	Deskripsi	Lokasi File	Timestamp
E-01	Screenshot terminal	curl -I https://nyamankost.ours.web.id: HTTP/2 200, server: cloudflare, PHP/8.5.11, XSRF-TOKEN (no HttpOnly), nyamankost-session (httponly), cf-ray, LiteSpeed		09 Oct 2026 09:37:03
E-02	Screenshot terminal	curl -I http://nyamankost.ours.web.id: HTTP/1.1 301 redirect ke HTTPS, Server: cloudflare, Connection: keep-alive		09 Oct 2026 09:39:03
E-03	Screenshot terminal	whatweb https://nyamankost.ours.web.id: 200 OK, PHP 8.5.11, Cloudflare, IP 104.21.92.41, cookies, Script[module], HTML5, HttpOnly[nyamankost-session], Title[NyamanKost]		09 Oct 2026 ~09:40
E-04	Screenshot terminal	curl https://nyamankost.ours.web.id/robots.txt: output: User-agent: * / Disallow: (kosong, tidak ada path yang diblokir untuk crawler)		09 Oct 2026 ~09:45

E-05.1	Screenshot terminal	curl https://nyamankost.ours.web.id/sitemap.xml (bagian 1): HTML 404 Not Found dengan Tailwind CSS class dan struktur MVC (indikasi Laravel framework)		09 Oct 2026 ~09:46
E-05.2	Screenshot terminal	curl sitemap.xml (bagian 2 - lanjutan): akhir respons HTML 404: h1=404, div=Not Found, closing tags body dan html		09 Oct 2026 ~09:46
E-06	Screenshot terminal	curl -I https://nyamankost.ours.web.id/wp-admin: HTTP/2 404, PHP/8.5.11 - konfirmasi tidak menggunakan WordPress CMS		09 Oct 2026 09:48:28
E-07	Screenshot terminal	nmap -sV -sC -p 80,443,22: Port 22 filtered, 80 & 443 open via Cloudflare; SSL cert wildcard *.ours.web.id; IP 172.67.186.51 (Cloudflare anycast)		09 Oct 2026 16:50

J. Threat Modeling

Skala Kemungkinan & Dampak: 1=Rendah, 2=Sedang, 3=Tinggi. Setiap baris memiliki bukti yang dapat dirujuk ke Evidence.

No	Aset	Nilai Aset	Ancaman Relevan	Kemung-kinan	Dampak	Prioritas	Evidence
1	Cookie XSRF-TOKEN (tanpa HttpOnly)	Tinggi	Pencurian CSRF token via JavaScript (XSS + CSRF chain)	2	3	Tinggi	E-01
2	Versi PHP terekspos (PHP/8.5.11)	Sedang	Eksploitasi CVE pada versi PHP yang diketahui spesifik	2	3	Tinggi	E-01, E-03
3	Mekanisme autentikasi/login	Tinggi	Brute force credential / credential stuffing (rate limiting belum diuji)	2	3	Tinggi	E-01 (session aktif)
4	Tidak ada header Content-Security-Policy	Sedang	XSS stored/reflected - tidak ada pembatasan sumber skrip	2	2	Sedang	E-01
5	Tidak ada header X-Frame-Options	Sedang	Clickjacking - halaman dapat di-embed dalam iframe pihak lain	2	2	Sedang	E-01
6	Framework PHP/Laravel (terindikasi)	Sedang	Debug mode aktif / route enumeration / mass assignment	1	3	Sedang	E-01, E-05.1
7	robots.txt kosong (Disallow kosong)	Rendah	Tidak ada pembatasan direktori - semua path dapat dicoba attacker	1	2	Rendah	E-04
8	LiteSpeed Web Server (versi tak terekspos)	Rendah	Kerentanan LiteSpeed belum dapat dikuantifikasi karena versi tidak diketahui	1	2	Rendah	E-01

K. Justifikasi Prioritas

Prioritas	Aset/Ancaman	Alasan Teknis	Bukti Pendukung
Tinggi	Cookie XSRF-TOKEN - XSS + CSRF Token Theft	Cookie CSRF token yang dapat dibaca JavaScript (tidak ada HttpOnly) membuka jalur pencurian token. Kondisi sudah terkonfirmasi dari evidence, tidak memerlukan asumsi tambahan.	E-01
Tinggi	PHP/8.5.11 terekspos - CVE Exploitation	Versi spesifik PHP terekspos di header X-Powered-By. Attacker dapat langsung mencari CVE di NVD. Informasi ini konkret dan actionable.	E-01, E-03
Tinggi	Login/Autentikasi - Brute Force	Session cookie aktif mengindikasikan ada mekanisme login. Belum ada bukti rate limiting. Perlu diuji pada pertemuan berikutnya.	E-01
Sedang	Tidak ada CSP - XSS	Tanpa Content-Security-Policy, browser tidak memiliki pembatasan skrip. Meningkatkan dampak jika ada XSS. Perlu dicari celah input dulu.	E-01
Sedang	Tidak ada X-Frame-Options - Clickjacking	Mudah diverifikasi dan dieksploitasi, namun memerlukan interaksi korban. Risiko nyata tapi dampak lebih rendah dari XSS.	E-01
Rendah	robots.txt kosong	Tidak ada info sensitif, tidak ada path yang terekspos secara tidak sengaja. Kontribusi minor ke attack surface.	E-04

L. Rencana Pengujian Berikutnya

Urutan	Target/Aset	Hipotesis yang Diuji	Metode yang Direncanakan	Prasyarat/Izin
1	Cookie XSRF-TOKEN / Form input	Apakah input form rentan XSS? Jika ya, apakah CSRF token dapat dicuri via document.cookie?	Injeksi payload XSS sederhana di semua form input; baca cookie via JS jika berhasil	Izin RoE Bagian 4 - diizinkan (input validation & injection)
2	PHP/8.5.11 runtime	Apakah versi ini memiliki CVE aktif yang dapat dieksploitasi dari lapisan aplikasi?	Lookup NVD/CVE database untuk PHP 8.5.11; analisis path eksploitasi	Tidak perlu izin tambahan - analisis pasif
3	Endpoint autentikasi/login	Apakah ada proteksi rate limiting pada form login? Apakah lockout mechanism ada?	Identifikasi form login; uji respons terhadap login gagal berulang; cek header respons	Izin RoE Bagian 4 - diizinkan (autentikasi & manajemen sesi)
4	Header keamanan (CSP, X-Frame-Options)	Apakah halaman rentan terhadap clickjacking dan eksekusi skrip eksternal?	Buat halaman HTML lokal dengan iframe ke target; uji embed; cek CSP di DevTools	Diizinkan - pengujian konfigurasi keamanan dari luar
5	Framework routes / endpoint tersembunyi	Apakah ada endpoint/route yang tidak tampil di UI namun dapat diakses?	Path fuzzing ringan dengan wordlist framework-specific (Laravel routes umum)	Diizinkan jika tidak aggressive; perhatikan rate limit

M. Analisis Mahasiswa

1. Apa aset paling bernilai yang ditemukan?

Aset paling bernilai adalah mekanisme autentikasi dan session management aplikasi. Hal ini terbukti dari keberadaan cookie nyamankost-session dan XSRF-TOKEN pada setiap respons (E-01), yang mengindikasikan sistem login aktif. Akses tidak sah ke sesi pengguna atau admin berpotensi memengaruhi seluruh data kost dan pengguna platform.

2. Temuan apa yang paling penting dan mengapa?

Temuan paling penting adalah cookie XSRF-TOKEN yang tidak memiliki flag HttpOnly (E-01). Cookie CSRF token yang dapat dibaca JavaScript secara langsung melemahkan proteksi CSRF. Jika terdapat celah XSS di bagian manapun aplikasi, attacker dapat mencuri token ini dan melakukan aksi palsu atas nama pengguna yang sedang login. Selain itu, eksposur versi PHP/8.5.11 (E-01, E-03) memberikan informasi teknis spesifik yang membantu attacker dalam reconnaissance.

3. Apa perbedaan antara data yang benar-benar terobservasi dan asumsi?

Terobservasi (fakta): Server cloudflare, PHP/8.5.11, LiteSpeed, XSRF-TOKEN tanpa HttpOnly, redirect HTTP ke HTTPS, robots.txt kosong, tidak ada sitemap.xml, /wp-admin 404, port 22 filtered, 80 & 443 open, SSL wildcard *.ours.web.id.

Asumsi (hipotesis): Framework adalah Laravel - hanya indikasi dari pola cookie dan Tailwind CSS, belum dikonfirmasi. Database kemungkinan MySQL - belum ada evidence. Ada form login - belum dikonfirmasi, hanya terindikasi dari session cookie aktif.

4. Mengapa suatu aset diberi prioritas Tinggi/Sedang/Rendah?

Prioritas Tinggi diberikan pada ancaman yang (1) kondisinya sudah terkonfirmasi dari evidence nyata, DAN (2) memiliki kemungkinan >= 2 serta dampak = 3. Cookie XSRF-TOKEN tanpa HttpOnly diprioritaskan Tinggi karena langsung terobservasi dari E-01. Ancaman Sedang memerlukan kondisi tambahan atau kemungkinan lebih rendah. Ancaman Rendah berkontribusi pada attack surface namun tidak langsung mengakibatkan kompromi.

5. Apa keterbatasan hasil scanning/enumeration Anda?

Semua traffic melewati Cloudflare - server origin tidak dapat diakses langsung, fingerprinting backend bersifat parsial. Tidak ada enumeration fitur fungsional aplikasi (form, API, endpoint login) - recon terbatas pada header HTTP dan tool fingerprinting. Nmap dilakukan di luar scope RoE. Belum ada analisis konten halaman yang sebenarnya - aset bisnis belum dapat diidentifikasi secara konkret.

N. Checklist Kepatuhan

[V] Target memiliki izin (RoE ditandatangani 25/09/2026).

[V] Semua aktivitas berada dalam scope (kecuali Nmap yang telah didokumentasikan pelanggarannya secara transparan).

[V] Tidak melakukan brute force atau DoS.

[V] Tidak mengeksploitasi temuan tanpa izin.

[V] Data sensitif telah disunting (nilai cookie dipotong di evidence).

[V] Command dan evidence lengkap (E-01 s.d. E-07 + E-04 diperbarui).

[V] Threat model terhubung dengan evidence (setiap ancaman memiliki ID evidence).

O. Pernyataan Individu

Saya menyatakan bahwa seluruh aktivitas praktikum yang saya dokumentasikan dilakukan terhadap target yang telah diberi izin, sesuai scope dan batasan pengujian sebagaimana tercantum dalam RoE Pentest KSI 5A 2026. Saya tidak memperluas target atau metode pengujian tanpa otorisasi. Aktivitas port scanning (Nmap) yang tercatat dalam E-07 diakui berada di luar Exclusion List RoE dan telah didokumentasikan secara transparan dalam Bagian F dan Checklist Kepatuhan.

Nama	M. Arifin Ilham
Tanda Tangan	
Tanggal	09/10/2026

PENDALAMAN THREAT MODELING - Output Wajib Bagian H

1. Inventarisasi Aset

No	Aset/Endpoint	Fungsi	Data/Fungsi Penting?	Evidence ID
1	Halaman utama (/)	Entry point platform sewa kost	Ya - title: Platform Sewa Kos Terpercaya	E-01, E-03
2	Session management (nyamankost-session)	Autentikasi & otorisasi pengguna	Ya - mengelola identitas login	E-01
3	CSRF Token (XSRF-TOKEN, no HttpOnly)	Proteksi dari CSRF attack	Ya - kritis; TIDAK ada HttpOnly	E-01
4	Web server LiteSpeed	Melayani konten web dari backend	Ya - infrastruktur utama	E-01, E-03
5	Cloudflare CDN/Proxy	DDoS protection, SSL termination, caching	Ya - keamanan lapisan jaringan	E-01, E-02, E-07
6	PHP Runtime v8.5.11	Menjalankan logika aplikasi backend	Ya - runtime utama; versi terekspos	E-01, E-03
7	robots.txt	Instruksi untuk web crawler	Tidak kritis - kosong	E-04
8	Framework backend (kemungkinan Laravel)	Routing, DB, autentikasi, business logic	Ya - fondasi seluruh aplikasi	E-01, E-05.1

2. Nilai Aset

Aset	Nilai (1-3)	Alasan Penilaian
Session management	3 (Tinggi)	Kompromi session = akses penuh ke akun pengguna
CSRF Token (XSRF-TOKEN)	3 (Tinggi)	Kegagalan CSRF protection = aksi tidak sah atas nama pengguna
PHP Runtime	2 (Sedang)	Versi terekspos membantu attacker, namun eksploitasi butuh CVE spesifik
Framework backend	2 (Sedang)	Kerentanan framework bisa berdampak luas namun butuh konfirmasi versi
Cloudflare CDN	2 (Sedang)	Melindungi infrastruktur - bukan aset yang bisa diserang dari lapisan aplikasi
Halaman utama	2 (Sedang)	Entry point penting namun tidak langsung menyimpan data sensitif
LiteSpeed Web Server	1 (Rendah)	Versi tidak terekspos - risiko belum dapat dikuantifikasi
robots.txt	1 (Rendah)	Kosong - tidak ada informasi sensitif

3. Identifikasi Ancaman

Aset	Evidence	Ancaman Relevan	Mengapa Ancaman Ini Relevan?
XSRF-TOKEN (tanpa HttpOnly)	E-01	Pencurian token CSRF via JS (XSS + CSRF chain)	Cookie dapat diakses via document.cookie - jika ada XSS, token langsung bisa dicuri untuk aksi palsu
PHP/8.5.11	E-01, E-03	Eksploitasi CVE versi PHP yang diketahui	Versi spesifik diketahui - attacker dapat lookup CVE database secara langsung
Tidak ada CSP header	E-01	XSS stored/reflected	Tanpa CSP, tidak ada kontrol atas skrip yang dapat dieksekusi di browser korban
Tidak ada X-Frame-Options	E-01	Clickjacking	Halaman dapat dimuat dalam iframe untuk mengelabui pengguna melakukan aksi tidak disadari
Session cookie aktif	E-01	Brute force login / session fixation	Session aktif mengindikasikan login ada; belum ada bukti rate limiting
Framework Laravel (terindikasi)	E-05.1	Debug mode aktif / route disclosure	Framework PHP sering memiliki debug mode yang tidak dinonaktifkan di production

4. Penilaian Kemungkinan dan Dampak

Aset/Ancaman	Kemungkinan (1-3)	Dampak (1-3)	Alasan
XSRF-TOKEN - XSS + CSRF	2	3	Perlu ada celah XSS dulu (kemungkinan sedang), tapi dampak pencurian sesi sangat tinggi
PHP 8.5.11 - CVE exploitation	2	3	Bergantung pada apakah CVE aktif ada untuk versi ini - belum diverifikasi
Tanpa CSP - XSS	2	2	Perlu input tidak tersanitasi - kemungkinan sedang, dampak sedang
Tanpa X-Frame-Options - Clickjacking	2	2	Mudah dieksploitasi namun membutuhkan interaksi korban
Login - Brute force	2	3	Bergantung apakah ada rate limiting - belum diuji pada pertemuan ini
Framework - debug/route disclosure	1	3	Kemungkinan rendah jika production setup benar, tapi dampak besar jika aktif

5. Tabel Prioritas Threat Model

No	Aset	Ancaman	Evidence	Nilai Aset	Kemung-kinan	Dampak	Prioritas	Alasan
1	XSRF-TOKEN	XSS + CSRF token theft	E-01	3	2	3	Tinggi	Cookie kritis tanpa HttpOnly - kondisi sudah terbukti dari evidence
2	PHP/8.5.11	CVE exploitation	E-01, E-03	2	2	3	Tinggi	Versi spesifik terekspos - actionable untuk attacker
3	Login/Auth	Brute force credential	E-01	3	2	3	Tinggi	Session aktif terdeteksi - login endpoint perlu diuji
4	Tanpa CSP	XSS reflected/stored	E-01	2	2	2	Sedang	Tidak ada pertahanan CSP - perlu uji input dulu
5	Tanpa X-Frame-Options	Clickjacking	E-01	2	2	2	Sedang	Mudah dieksploitasi namun perlu interaksi korban
6	Framework Laravel	Debug/route enumeration	E-05.1	2	1	3	Sedang	Kemungkinan rendah, tapi dampak besar jika debug aktif
7	robots.txt kosong	Crawling direktori	E-04	1	1	2	Rendah	Kontribusi minor ke attack surface
8	LiteSpeed server	Kerentanan server	E-01	1	1	2	Rendah	Versi tidak terekspos - risiko tidak dapat dikuantifikasi

6. Attack Surface Map Sederhana

Entry Point	Aset/Fungsi	Ancaman	Prioritas	Evidence
Setiap halaman web (browser)	Cookie XSRF-TOKEN (no HttpOnly)	XSS ke Pencurian CSRF Token ke Aksi palsu atas nama pengguna	Tinggi	E-01
Response HTTP header	PHP/8.5.11 terekspos	Reconnaissance ke CVE Lookup ke Exploitation via kerentanan PHP	Tinggi	E-01, E-03
Form input (belum dikonfirmasi)	Database / logika aplikasi	SQL Injection / XSS stored pada form pencarian atau input lain	Tinggi	E-01 (session aktif = ada interaksi DB)
URL bar / iframe (no X-Frame-Options)	Halaman utama aplikasi	Clickjacking - pengguna melakukan aksi tanpa sadar dalam iframe	Sedang	E-01
HTTP response (tanpa CSP)	Browser pengguna	Eksekusi skrip pihak ketiga / XSS reflected tanpa pembatasan sumber	Sedang	E-01

7. Testing Priority List

Urutan	Target/Aset	Hipotesis	Evidence	Alasan Diprioritaskan	Metode yang Direncanakan
1	Cookie XSRF-TOKEN / Form input	CSRF token dapat dicuri via XSS karena tidak ada HttpOnly	E-01	Kondisi sudah terkonfirmasi dari evidence langsung	Uji XSS di semua form input; jika berhasil baca cookie via JS
2	PHP/8.5.11 runtime	Versi PHP ini memiliki CVE yang bisa dieksploitasi	E-01, E-03	Versi spesifik sudah diketahui - langsung cari di NVD	Lookup NVD untuk PHP 8.5.11; analisis path eksploitasi
3	Endpoint autentikasi/login	Tidak ada rate limiting pada form login	E-01	Session aktif terdeteksi - login endpoint kemungkinan ada	Identifikasi form login; uji respons login gagal berulang
4	Security header (CSP, X-Frame-Options)	Halaman rentan clickjacking dan XSS	E-01	Header tidak ada - mudah diverifikasi	Buat halaman HTML lokal dengan iframe ke target; cek DevTools
5	Framework routes / endpoint tersembunyi	Ada endpoint sensitif yang tidak tampil di UI	E-05.1	Framework MVC biasanya punya route tersembunyi	Path fuzzing ringan dengan wordlist Laravel-specific

8. Refleksi Threat Modeling

Apa aset paling bernilai pada target Anda? Jelaskan berdasarkan evidence.

Cookie nyamankost-session dan XSRF-TOKEN adalah aset paling bernilai yang teridentifikasi. Keduanya terhubung langsung ke mekanisme autentikasi dan proteksi CSRF. Evidence E-01 secara langsung mengkonfirmasi keberadaan dan konfigurasi cookie ini - ini adalah fakta observasi, bukan asumsi.

Ancaman apa yang paling relevan terhadap aset tersebut? Mengapa?

Ancaman paling relevan adalah chaining XSS + CSRF token theft. Alasan: (1) cookie XSRF-TOKEN tidak memiliki flag HttpOnly (terkonfirmasi E-01) - kondisi teknis eksploitasi sudah terpenuhi; (2) jika XSS ditemukan di manapun, token ini dapat langsung dicuri untuk melakukan aksi palsu atas nama pengguna.

Mengapa aset prioritas pertama harus diuji lebih dahulu?

XSRF-TOKEN tanpa HttpOnly diuji pertama karena kondisinya sudah terkonfirmasi dari evidence tanpa memerlukan scanning tambahan. Pengujian XSS pada input form adalah langkah alami berikutnya yang sesuai scope RoE dan langsung membuktikan atau menyangkal hipotesis.

Apa informasi yang masih belum diketahui dan perlu diverifikasi pada tahap berikutnya?

Apakah ada form input pengguna (login, pencarian, kontak)? Versi framework Laravel - menentukan CVE spesifik. Apakah ada rate limiting pada login? Apakah debug mode framework aktif di production? Apakah ada endpoint API yang tidak terdokumentasi?

Apa perbedaan antara fakta hasil recon dan hipotesis ancaman Anda?

Fakta: XSRF-TOKEN tidak ada HttpOnly (E-01). PHP/8.5.11 terekspos (E-01). Tidak ada CSP/X-Frame-Options (E-01). robots.txt kosong (E-04). /wp-admin 404 (E-06). SSL wildcard valid (E-07).
Hipotesis: Framework adalah Laravel - belum dikonfirmasi. Ada form login - belum dikonfirmasi. CVE aktif untuk PHP 8.5.11 - belum diverifikasi. XSS ada di aplikasi - belum diuji.

9. Output Akhir yang Harus Ada

Inventaris aset (8 aset teridentifikasi) [V]
Nilai aset (skala 1-3 dengan justifikasi) [V]
Ancaman relevan (berbasis evidence nyata) [V]
Evidence untuk setiap keputusan penting [V]
Penilaian kemungkinan dan dampak (skala 1-3 dengan alasan) [V]
Prioritas Tinggi/Sedang/Rendah [V]
Attack surface map sederhana (5 entri) [V]
Testing Priority List (5 target) [V]
Refleksi dan keterbatasan [V]